
Q1.SQL Injection Attack

Definition

An **SQL Injection attack** is a technique where an attacker inserts **malicious SQL queries** into input fields to gain unauthorized access to a database.

Working

- Web applications take input from users (login forms).
 - If input is **not validated**, attacker injects SQL code.
 - The database executes the modified query.
 - This may lead to **unauthorized access or data leakage**.
-

Original Query:

</> SQL

```
SELECT * FROM users WHERE username='user' AND password='pass';
```

Injected Input:

username: ' OR '1'='1

password: anything

Modified Query:

</> SQL

```
SELECT * FROM users WHERE username='' OR '1'='1' AND password='anything';
```

👉 Condition `'1'='1'` is always true → attacker gets access without valid credentials.

Effects

- Unauthorized login
- Data theft
- Data modification

Prevention

- Use **prepared statements**
- Validate user input
- Use **stored procedures**
- Apply **least privilege access**

Q2Write a note on: ICMP flood attack.

I've created a note for you titled "**ICMP Flood Attack Overview**" with details on how it works, its key characteristics, and mitigation strategies.

ICMP Flood Attack (Ping Flood)

An **ICMP Flood Attack**, also known as a **Ping Flood**, is a common type of Denial-of-Service (DoS) or Distributed Denial-of-Service (DDoS) attack. In this attack, the offender attempts to overwhelm a targeted device with **ICMP Echo Request** (ping) packets.

How it Works:

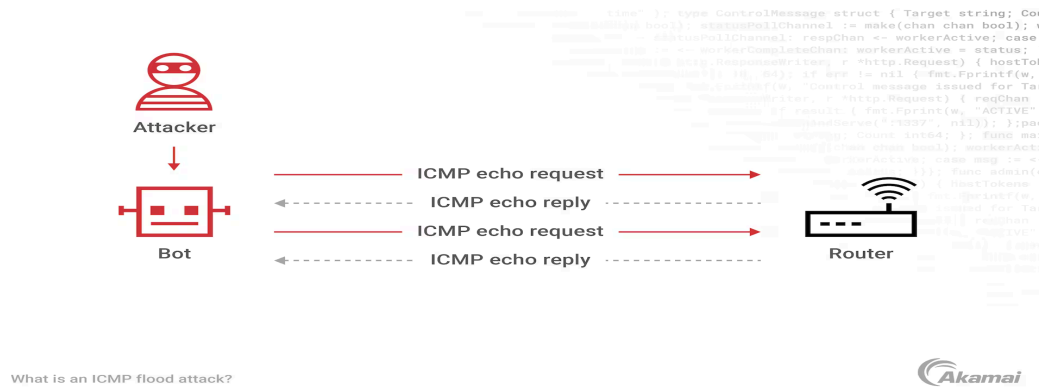
1. **Request Overload:** The attacker sends a large volume of ICMP Echo Request packets to the target's IP address.
2. **Resource Exhaustion:** For every request received, the target machine is mandated by the protocol to send back an **ICMP Echo Reply** packet.
3. **Denial of Service:** As the target attempts to respond to the massive influx of requests, its incoming/outgoing network bandwidth and CPU resources are exhausted, causing the system to slow down or crash.

Key Characteristics:

- **Symmetry:** The amount of traffic sent is roughly equal to the amount the target tries to send back.
- **IP Spoofing:** Attackers often spoof the source IP to hide their identity and redirect replies.
- **Distributed Nature:** In a **DDoS** scenario, a botnet is used to send pings simultaneously from many locations.

Mitigation Strategies:

- **Rate Limiting:** Limiting the number of ICMP packets processed per second.
- **Disabling ICMP:** Configuring firewalls to ignore ICMP requests (though this can affect diagnostics).
- **Cloud Protection:** Using services that scrub malicious traffic before it reaches your network.



Q3. Pretty Good Privacy (PGP)

PGP (Pretty Good Privacy) is an encryption program used to provide **security for emails and data communication**.

Features

- Provides **confidentiality, integrity, authentication, and non-repudiation**
- Uses a combination of **symmetric key encryption and public key encryption**
- Uses **hash functions** for message integrity

Working

1. The sender creates a **message digest (hash)** of the message.
2. The digest is encrypted using the **sender's private key** → digital signature.
3. The message + signature is encrypted using a **symmetric key**.
4. The symmetric key is encrypted using the **receiver's public key**.
5. At the receiver side, the process is reversed to **decrypt and verify** the message.

Applications

- Secure email communication
- File encryption

Q4. IPsec (Internet Protocol Security)

IPsec is a set of protocols used to **secure IP communication** by encrypting and authenticating data packets.

Features

- Provides **confidentiality, integrity, and authentication**
- Works at the **network layer**
- Widely used in **VPNs (Virtual Private Networks)**

Modes of Operation

- **Transport Mode** – Encrypts only the data part of the packet
- **Tunnel Mode** – Encrypts the entire IP packet

Protocols Used

- **AH (Authentication Header)** – Provides integrity and authentication
- **ESP (Encapsulating Security Payload)** – Provides encryption, integrity, and authentication

Applications

- Secure network communication
 - Site-to-site VPN
 - Remote access VPN
-

Denial of service (DOS) attack

A DoS attack is a type of cyber attack where the attacker attempts to make a machine or network resource unavailable to its intended users by enormous the system with a flood of traffic, or by exploiting vulnerabilities to crash or disable it.

There are two main types of DoS attacks:

1. DoS (Single Source Attack)

A traditional Denial of Service attack is typically launched from a single source, such as one computer or network connection.

It sends an enormous amount of traffic or requests to a target system, causing it to slow down, crash, or become temporarily inaccessible.

Example:

Ping of Death — where a malicious actor sends an oversized ping packet that exceeds the buffer limits of the target, causing it to crash.

DDoS (Distributed Denial of Service Attack)

- A Distributed Denial of Service attack is a more advanced version of DoS, involving multiple systems that work together to flood the target.
- **Example:**
- **HTTP Flood** — attackers send a large volume of seemingly legitimate HTTP requests to a web server.

Impact of a DoS Attack:

Downtime for websites or services.

Reputation damage for businesses or individuals affected.

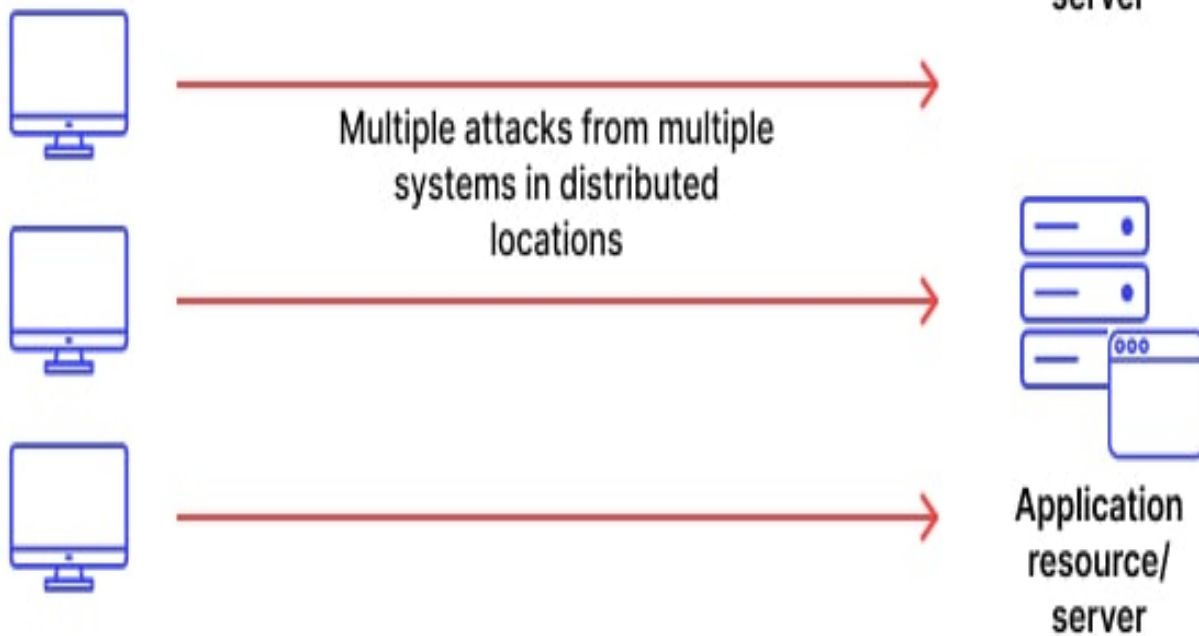
Financial losses due to the disruption of business operations.

Loss of customer trust and potentially long-term effects on relationships.

DoS attack



DDoS attack



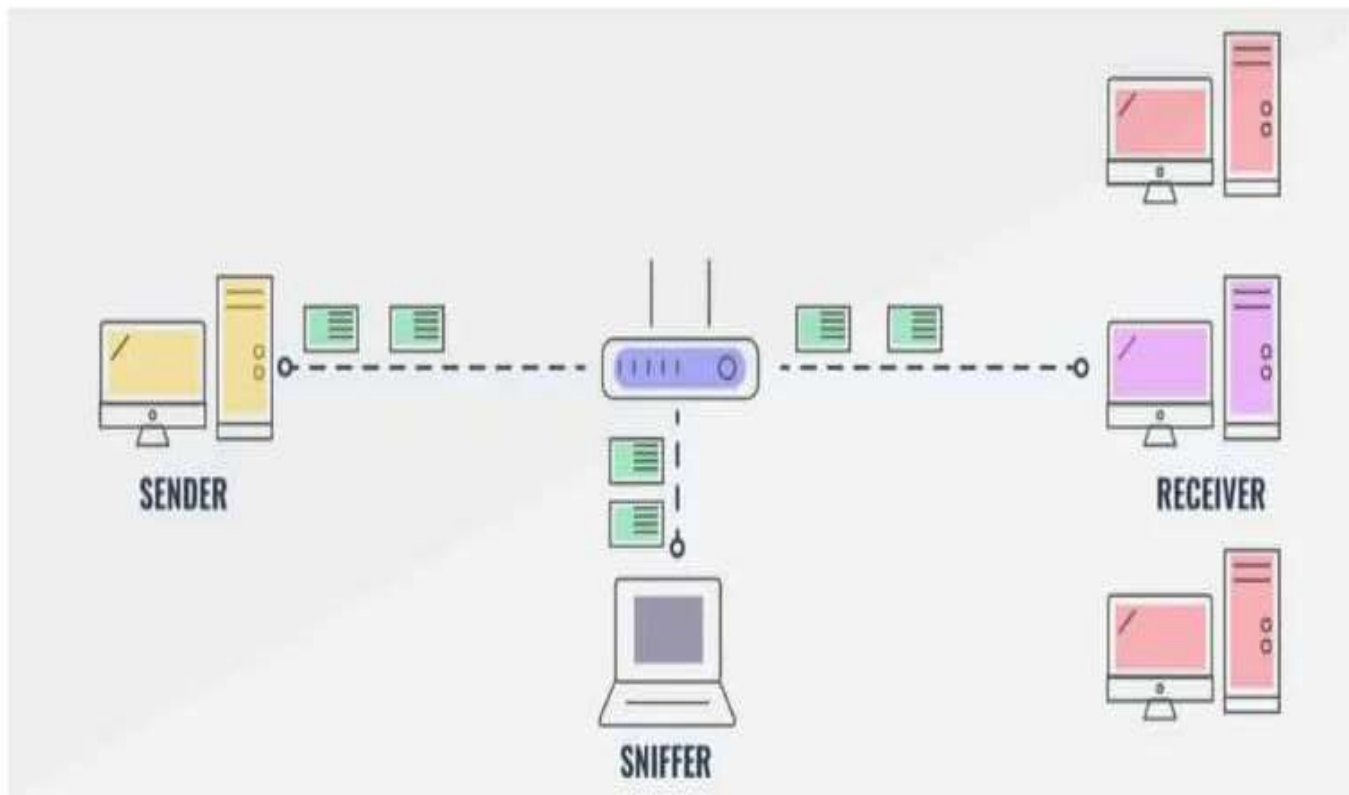
packet sniffing

- Packet sniffing is a hacking technique that involves capturing data packets traveling through a network.
- This can be used to steal sensitive information or launch other attacks.

How it works

- Packet sniffers monitor network traffic
- They capture packets as they travel through a network
- They look inside the packets to discover any valuable information

A packet sniffing attack (or simply a sniffing attack) is a network-created threat where a malicious entity captures network packets intending to steal data traffic that may have been left unencrypted.



Packet sniffing tools:

Wireshark: Traces malicious traffic back to the source

Colasoft Capsa: Provides in-depth network analysis

NetworkMiner: A passive network sniffing tool that captures every packet

Kismet: An open-source software tool for wireless network monitoring

OmniPeek: A packet sniffer and network analyzer tool

ARP Spoofing

- ARP translates Internet Protocol (IP) addresses to a Media Access Control (MAC) address, and vice versa
- **ARP spoofing** is a technique by which an attacker sends (spoofed) ARP messages onto a local area network.
- Generally, the aim is to associate the attacker's MAC address with the IP address of another host, such as the default gateway, causing any traffic meant for that IP address to be sent to the attacker instead.

The Steps of an ARP Spoofing Attack

1. The attacker gains access to the local network and then scans it to find device IP addresses.
2. The attacker uses a spoofing tool, like [Arpspoof](#), to forge ARP responses.
3. ARP packets are sent that contain the attacker's MAC paired with the victim's IP address, tricking the router and PC to connect to the attacker instead of each other.
4. The ARP cache is updated, and thus the PC and router keep communicating with the attacker.

ARP Spoofing Attack

